

☒ Easy (10 Questions)

Q1. What does the "C" in the CIA triad stand for?

- A) Cybersecurity
- B) Control
- C) Confidentiality
- D) Cryptography

Answer: C

☒ *Confidentiality means keeping data private and secure from unauthorized access.*

Q2. Which of the following best defines a vulnerability?

- A) The impact of a successful attack
- B) A weakness that can be exploited
- C) A hacker trying to steal data
- D) A network firewall

Answer: B

☒ *A vulnerability is a flaw or weakness that could be exploited by a threat.*

Q3. What is the primary goal of Information Security?

- A) Selling data
- B) Speeding up computers
- C) Protecting data confidentiality, integrity, and availability
- D) Upgrading operating systems

Answer: C

☒ *CIA triad forms the foundation of information security objectives.*

Q4. What is considered a **threat** in cybersecurity?

- A) An antivirus software
- B) A hacker attempting a brute-force attack
- C) A strong password
- D) An encrypted file

Answer: B

☒ *A threat is any potential danger to information or systems.*

Q5. Which of the following is most related to availability?

- A) Data encryption
- B) QoS
- C) Firewalls
- D) Passwords

Answer: B

☒ *QoS ensures resources are available when needed, thus supporting availability.*

Q6. The term "Risk" in InfoSec represents:

- A) Number of employees in a company
- B) Cost of servers
- C) Probability of an attack and its impact

D) Quality of software

Answer: C

☒ *Risk is calculated by evaluating threat, vulnerability, and potential impact.*

Q7. A firewall primarily protects against:

A) Internet downtime

B) Power failure

C) Unauthorized access

D) Data formatting

Answer: C

☒ *Firewalls filter traffic to prevent unauthorized access.*

Q8. Which of the following is a **threat** but not a **vulnerability**?

A) Unpatched OS

B) Weak passwords

C) Hacker with malware

D) Open port

Answer: C

☒ *Hacker with malware = active threat.*

Q9. A risk can exist **only** if:

A) The system is offline

- B) There is both a vulnerability and a threat
- C) Antivirus is updated
- D) Data is encrypted

Answer: B

☒ *Risk = Threat × Vulnerability × Impact.*

Q10. QoS stands for:

- A) Quality of Security
- B) Quick Online Security
- C) Quality of Service
- D) Query over Software

Answer: C

☒ *QoS manages bandwidth and traffic priorities in networking.*

☒ Medium (20 Questions)

Q11. Which of the following represents a **technical vulnerability**?

- A) Phishing email
- B) Misconfigured database
- C) Insider threat
- D) Lost USB drive

Answer: B

☒ *Technical vulnerability = system or software flaw.*

Q12. What does **integrity** ensure in CIA triad?

- A) Data cannot be seen
- B) Data is correct and unaltered
- C) Data is fast
- D) Data is in the cloud

Answer: B

☒ *Integrity ensures data remains accurate and unchanged.*

Q13. A system is said to be **at risk** when:

- A) There are multiple users
- B) Its vulnerabilities can be exploited
- C) It uses Linux OS
- D) It is not connected to the internet

Answer: B

☒ *Exploitable vulnerabilities lead to risk.*

Q14. Which of the following is an **example of availability** control?

- A) Access Control Lists
- B) Encryption
- C) RAID-based storage
- D) File hashing

Answer: C

☒ *RAID ensures system uptime and data redundancy.*

Q15. Investing in cybersecurity helps reduce:

- A) Hardware speed
- B) Breach impact and recovery cost
- C) Software licensing
- D) Employee count

Answer: B

☒ *Security saves money in the long run by preventing damage.*

Q16. How can QoS contribute to cybersecurity?

- A) By encrypting emails
- B) By prioritizing legitimate traffic during DDoS
- C) By blocking users
- D) By generating logs

Answer: B

☒ *QoS prioritizes critical traffic and helps prevent denial of service.*

Q17. What best defines a **zero-day vulnerability**?

- A) Known bug with a patch
- B) Outdated antivirus
- C) An unpatched, unknown vulnerability
- D) Router misconfiguration

Answer: C

☒ *Zero-day = vulnerability discovered and exploited before fix is released.*

Q18. Who is typically responsible for **ensuring information security** in an organization?

- A) CFO
- B) CISO
- C) CIO
- D) COO

Answer: B

☒ *Chief Information Security Officer oversees InfoSec strategy.*

Q19. Which one is an **administrative control**?

- A) Antivirus software
- B) Password policy
- C) Firewalls
- D) IDS

Answer: B

☒ *Policies and procedures fall under administrative controls.*

Q20. A distributed denial of service (DDoS) attack impacts which element of CIA triad?

- A) Confidentiality
- B) Integrity
- C) Availability

D) None

Answer: C

☒ *DDoS targets availability by overwhelming system resources.*

☒ Medium (Contd.) – Q21 to Q30

Q21. What is an example of a **physical threat** to information security?

A) SQL injection

B) Unpatched system

C) Power outage

D) Malware

Answer: C

☒ *Physical threats are environmental, like fire, theft, flood, or power loss.*

Q22. An attacker uses social engineering to gain access. What kind of threat is this?

A) Insider threat

B) Environmental threat

C) Human threat

D) Logical threat

Answer: C

☒ *Social engineering = human-based threat vector.*

Q23. Which of the following is a **risk mitigation** technique?

- A) Ignore the risk
- B) Accept all vulnerabilities
- C) Implement multi-factor authentication
- D) Disable backups

Answer: C

☒ *MFA reduces the likelihood of unauthorized access = mitigation strategy.*

Q24. When is **encryption** most useful?

- A) When data is being printed
- B) When data is at rest or in transit
- C) When data is deleted
- D) When data is compressed

Answer: B

☒ *Encryption protects confidentiality both in storage and in communication.*

Q25. A company backs up its critical data every night. What part of CIA triad does this support?

- A) Confidentiality
- B) Availability
- C) Authentication
- D) Authorization

Answer: B

☒ *Backups ensure recovery and continued availability after failure or attack.*

Q26. A security risk assessment involves:

- A) Writing software
- B) Determining how much data can be lost
- C) Identifying and evaluating potential threats and vulnerabilities
- D) Checking social media

Answer: C

☒ *Risk assessment identifies and measures exposure to threats.*

Q27. A company faces reputational damage after a data breach. What kind of cost is this?

- A) Direct cost
- B) Tangible cost
- C) Indirect cost
- D) Hardware cost

Answer: C

☒ *Reputation, customer loss, and trust issues are indirect consequences.*

Q28. If a network is attacked and resources become unavailable, this violates which principle?

- A) Confidentiality
- B) Integrity
- C) Authenticity

D) Availability

Answer: D

☒ *Availability is compromised when systems or data are inaccessible.*

Q29. Which of the following helps maintain **integrity** of data?

A) Firewalls

B) Hashing

C) Bandwidth throttling

D) Data backups

Answer: B

☒ *Hashes ensure data hasn't been tampered with.*

Q30. Which situation best represents a **low risk** scenario?

A) High vulnerability, no threats

B) Low vulnerability, active threats

C) No vulnerability, no threats

D) High vulnerability, many threats

Answer: C

☒ *No vulnerabilities and threats = low or zero risk.*

☒ **Hard (10 Questions)**

Q31. Which formula best represents **quantitative risk assessment**?

- A) Risk = Impact + Likelihood
- B) Risk = (Threat + Vulnerability) ÷ 2
- C) Risk = Asset Value × Threat × Vulnerability
- D) Risk = Asset Value – Control Strength

Answer: C

☒ *This formula quantifies risk based on measurable factors.*

Q32. Which of the following is **NOT** a part of the NIST Cybersecurity Framework core functions?

- A) Identify
- B) Protect
- C) Defend
- D) Recover

Answer: C

☒ *The 5 NIST core functions are: Identify, Protect, Detect, Respond, Recover.*

Q33. Which technique ensures that a **message has not been altered** during transmission?

- A) Symmetric encryption
- B) Hash-based Message Authentication Code (HMAC)
- C) Access control
- D) Two-factor authentication

Answer: B

☒ *HMAC combines hashing with a secret key to ensure integrity and authenticity.*

Q34. Which control type is a **security camera** classified as?

- A) Detective physical control
- B) Preventive logical control
- C) Compensating administrative control
- D) Corrective technical control

Answer: A

☒ *It detects activity and is a physical control mechanism.*

Q35. Which **ISO/IEC standard** relates specifically to Information Security Management Systems (ISMS)?

- A) ISO 9001
- B) ISO 27001
- C) ISO 14001
- D) ISO 31000

Answer: B

☒ *ISO 27001 is the international standard for managing InfoSec.*

Q36. Which of the following best defines **security through obscurity**?

- A) Hiding system vulnerabilities
- B) Implementing multi-layered security
- C) Trusting obscurity as the main defense

D) Using open-source security practices

Answer: C

☒ *Relies on secrecy of design rather than strength = bad practice.*

Q37. What distinguishes **threat modeling** from a regular risk assessment?

A) Threat modeling is faster

B) Threat modeling focuses on software design stage

C) Risk assessment is only for physical assets

D) Risk assessment is only quantitative

Answer: B

☒ *Threat modeling is proactive and done during the design/development phase.*

Q38. In risk management, what does "**transfer the risk**" mean?

A) Ignore the risk

B) Share the risk with another organization

C) Buy insurance or outsource

D) Accept the risk

Answer: C

☒ *Risk transfer involves shifting liability (e.g., cyber insurance, outsourcing).*

Q39. A company encrypts customer data, enforces strong authentication, and performs regular audits. Which principle is being followed?

A) Principle of Least Privilege

- B) Defense in Depth
- C) Denial by Default
- D) Fail Secure

Answer: B

☒ *Multiple layers of protection = Defense in Depth strategy.*

Q40. What is the **main goal** of Information Security Governance?

- A) Eliminate all cyber threats
- B) Maximize IT spending
- C) Align security efforts with business objectives
- D) Automate security policies

Answer: C

☒ *Governance ensures security supports organizational goals.*

☒ Summary

You now have:

- - ☒ **Detailed theory** covering: Why InfoSec, Money Factor, Internet Stats, V/T/R, and QoS
- - ☒ **40 MCQs:**

- 10 Easy

- 20 Medium

- 10 Hard

- ☒ All questions are answered and explained.